ISTQB® Certified Tester

Advanced Level — **Security Tester** (CT-SEC, Syllabus 2016)

CHAPTER 2

Security Testing Purposes, Goals and Strategies

Complete Study Guide

Chapter fact	Value
Syllabus sections covered	2.1 Introduction · 2.2 The Purpose of Security Testing · 2.3 The Organizational Context · 2.4 Security Testing Objectives · 2.5 The Scope and Coverage of Security Testing Objectives · 2.6 Security Testing Approaches · 2.7 Improving the Security Testing Practices
Learning objectives	10 examinable (AS-2.2.1 – AS-2.7.1) · K2 = 4 · K3 = 3 · K4 = 3
Recommended teaching time	130 minutes — **11 points**, 5.1 points per teaching hour
Questions in the exam	**6 of 45 questions · 11 of 80 points.** K2 = 2 · **K3 = 3** · K4 = 1. Guaranteed: **AS-2.4.2, 2.5.1, 2.6.3** (K3). Two K2 from 2.2.1/2.3.1/2.4.1/2.4.3; one K4 from 2.6.1/2.6.2/2.7.1
Exam format	45 questions · **80 points** · **120 minutes** (150 with the 25% non-native-language allowance) · pass mark 65% = **52 points** · K2 = 1 pt · K3 = 2 pts · K4 = 3 pts
Keywords	cross-site scripting · data obfuscation · denial of service · information assurance · security policy · security testing · security vulnerability · software lifecycle · test strategy
Official sample-exam questions	**#5 – #10** (1 + 1 + 2 + 2 + 3 + 2 points)

Built exclusively from the ISTQB® Advanced Level Security Tester syllabus (2016), the official Sample Exam (questions and answers, GA March 2016) and the ISTQB® exam structure tables.

Study this single file to master Chapter 2.

Contents

Section 1 — Syllabus Explanation....4
§2.1 — Introduction (no learning objective, but heavily used)....5
AS-2.2.1 (K2) — The Purpose of Security Testing....5
AS-2.3.1 (K2) — The Organizational Context....6
AS-2.4.1 (K2) — The Alignment of Security Testing Goals....6
AS-2.4.2 (K3) — Identification of Security Test Objectives....7
AS-2.4.3 (K2) — Information Assurance versus Security Testing....7
AS-2.5.1 (K3) — Scope and Coverage of Security Test Objectives....8
§2.6 — Security Testing Approaches: strategy versus approach....8
AS-2.6.1 (K4) — Analysis of Security Test Approaches....8
AS-2.6.2 (K4) — Analysis of Failures in Security Test Approaches....9
AS-2.6.3 (K3) — Stakeholder Identification....10
AS-2.7.1 (K4) — Improving Security Testing Practices....10
Section 2 — Key Concepts....12
2.1 The storyline of Chapter 2....12
2.2 What security testing is and why it is needed....12
2.3 Alignment, objectives and scope....13
2.4 Approaches, failures, stakeholders and improvement....15
2.5 Fuzzy points clarified....17
2.6 Chapter 2 keyword glossary....17
Section 3 — Tables and Summaries....19
Section 4 — Demo Questions with Answers....21
Part A — The 6 official Chapter 2 questions....21
Part B — 20 additional syllabus-derived questions....23
Most Important Questions From This Chapter....29
Section 5 — Exam Tricks....30
5.1 Frequently tested topics (evidence-based)....30
5.2 Common distractors observed....30
5.3 Keyword recognition (map words → answers)....30
5.4 Typical traps....31
5.5 How to eliminate wrong answers....31
5.6 Scenario-solving shortcuts....31
5.7 Common candidate mistakes....31
5.8 Mnemonics that carry the whole chapter....31
5.9 Chapter 2 mind map....32
Section 6 — Revision Notes....33
6.1 One-page chapter summary....33
6.2 Key definitions to memorize....33
6.3 High-priority concepts (study first)....33
6.4 Last-minute revision sheet....33
6.5 Memorization checklist....34
6.6 Exam-day quick review....34

In Word, right-click the table of contents and choose "Update Field" → "Update entire table" to refresh the page numbers.

How to use this guide

Section 1 explains all ten learning objectives — read it once, slowly. **Section 2** explains every key concept from the ground up — plain words, how it works, a worked example, the exam angle, and what it is easily confused with — and ends with the chapter's **fuzzy points clarified**. If the syllabus wording in Section 1 feels dense, read the matching Section 2 card first. **Section 3** holds the tables to reproduce from memory; **table 3.2 (stakeholder → benefit)** and **table 3.3 (security vs functional objective)** pay directly. **Section 4** is the question bank. **Section 5** is exam tactics, **Section 6** is the revision sheet for the night before.

What makes Chapter 2 unusual: three K3 questions are guaranteed, each worth 2 points, and each is decided by a short list — **six stakeholder benefits**, **two scope consequences**, **three sources of objectives**. That is **6 points from one evening of learning**, the best return in the first half of the syllabus.

The rule that decides the 3-point question: everything flows from the **security policy**. When a scenario shows sporadic, unfunded, uncoordinated testing, the first step is to **create a security policy and a security testing policy and show how the approach aligns with them** — not to present an approach, a list of holes, or the lawyers.

Suggested schedule: Day 1 — Section 1 up to AS-2.5.1. Day 2 — Section 1 from §2.6, and Section 3. Day 3 — Section 4 Part A and Section 2. Day 4 — Section 4 Part B and Section 5. Day 5 onwards — redo the questions you missed and re-read Section 2's fuzzy points. Night before — Section 6.

Section 1 — Syllabus Explanation

Chapter 2, **Security Testing Purposes, Goals and Strategies**, carries **10 learning objectives** across seven sub-chapters (2.1 Introduction · 2.2 Purpose · 2.3 Organizational Context · 2.4 Objectives · 2.5 Scope and Coverage · 2.6 Approaches · 2.7 Improving Practices). The Exam Structure Table allocates **6 questions** and **11 of the 80 points**. Recommended teaching time is **130 minutes — 5.1 points per teaching hour**, one of the better returns on the paper.

Three **K3** objectives are guaranteed a 2-point question each: **identifying test objectives (AS-2.4.2)**, **scope versus asset integrity (AS-2.5.1)** and **stakeholder benefits (AS-2.6.3)**. Together they are **6 of the chapter's 11 points**, and each of them is decided by a short list you can learn in an evening. Two K2 questions come from the four "why and where" objectives, and one 3-point K4 comes from the three analysis objectives.

LO ID	K	Objective (syllabus statement)	Qs	Pts
AS-2.2.1	K2	Understand why security testing is needed in an organization, including benefits such as risk reduction and higher levels of confidence and trust.	2 of 4†	1 each
AS-2.3.1	K2	Understand how project realities, business constraints, software development lifecycle, and other considerations affect the mission of the security testing team.	2 of 4†	1 each
AS-2.4.1	K2	Explain why security testing goals and objectives must align with the organization's security policy and other test objectives in the organization.	2 of 4†	1 each
AS-2.4.2	**K3**	For a given project scenario, demonstrate the ability to identify security test objectives based on functionality, technology attributes and known vulnerabilities.	**1**	**2**
AS-2.4.3	K2	Understand the relationship between information assurance and security testing.	2 of 4†	1 each
AS-2.5.1	**K3**	For a given project, demonstrate the ability to define the relationship between security test objectives and the need for strength of integrity of sensitive digital and physical assets.	**1**	**2**
AS-2.6.1	**K4**	Analyze a given situation and determine which security testing approaches are most likely to succeed.	1 of 3‡	3
AS-2.6.2	**K4**	Analyze a situation in which a given security testing approach failed, identifying the likely causes of failure.	1 of 3‡	3
AS-2.6.3	**K3**	For a given scenario, demonstrate the ability to identify the various stakeholders and illustrate the benefits of security testing for each stakeholder group.	**1**	**2**
AS-2.7.1	**K4**	Analyze KPIs to identify security testing practices needing improvement and elements not needing improvement.	1 of 3‡	3
Chapter 2 total	—	**K2 = 2 · K3 = 3 · K4 = 1**	**6**	**11**

*† Two K2 questions drawn from AS-2.2.1, 2.3.1, 2.4.1, 2.4.3 — the Sample Exam drew **2.2.1** (Q5) and **2.4.3** (Q6). ‡ One K4 question drawn from AS-2.6.1, 2.6.2, 2.7.1 — the Sample Exam's Q9 is a failed-approach scenario (**2.6.2**).*

Exam allocation you must know

Chapter 2 = **6 questions / 11 points**. In the official Sample Exam these are questions **#5 to #10** (1 + 1 + 2 + 2 + 3 + 2 points). It is the **fourth-largest chapter by points** after Chapters 4, 3 and 5 — and **cheaper per point** than any of them.

The one thing that decides this chapter

Everything flows from the security policy. The organization's **security policy** (approved by senior management) comes first; the **security testing policy** is written from it and must align with it; the **strategy** formalizes direction; **approaches** implement the strategy per project; **objectives** define scope. When a scenario shows sporadic, unfunded, uncoordinated testing, the fix is **policy first** — the official answer to the 3-point Q9 is "**create a security policy and security testing policy and demonstrate how that aligns with your proposed testing approach**".

§2.1 — Introduction (no learning objective, but heavily used)

Before applying specialized techniques you must understand **why security testing is needed, what its purpose is and how it fits into the organization**. Security testing **differs from other forms of functional testing in two significant areas** [ATTA syllabus]:

1. **Standard techniques for selecting test input data may miss important security issues.**
2. **The symptoms of security defects are very different** from those found with other types of functional testing.

Security testing assesses a system's vulnerability to threats by attempting to compromise the system's security policy. The syllabus lists the threats to explore — these reappear as distractors and as stems throughout the paper:

Threats to explore during security testing

Threat	Syllabus description
Unauthorized copying	Of applications or data.
Unauthorized access control	Ability to perform tasks for which the user **does not have rights**. **User rights, access and privileges** are the focus — this information **should be available in the system specifications**.
Unintended side effects	Software that does its job but has a side effect — a **media player that plays audio correctly but writes files to unencrypted temporary storage**, exploitable by **software pirates**.
Cross-site scripting (XSS)	**Code inserted into a web page that may be exercised by subsequent users**; this code may be malicious.
Buffer overflow (overrun)	Data strings **longer than the code can handle** entered into a UI field — an **opportunity for running malicious code instructions**.
Denial of service	Prevents users from interacting with an application, e.g. **overloading a web server with "nuisance" requests**.
Man in the middle	**Interception, mimicking and/or altering and relaying** of communications (e.g. **credit card transactions**) by a third party **while the user remains unaware**.
Breaking encryption	Breaking the codes used to protect sensitive data.
Logic bombs ("Easter eggs")	Maliciously inserted code that **activates only under certain conditions** (e.g. a specific date) and may **delete files or format disks**.

Security testing must be integrated with all other development and testing activities, considering the organization's **unique needs, existing security policies, current security testing skill sets and existing test strategies**.

AS-2.2.1 (K2) — The Purpose of Security Testing

Original syllabus statement

Understand why security testing is needed in an organization, including benefits to the organization such as risk reduction and higher levels of confidence and trust.

Statement	Syllabus wording
What it cannot do	Like testing in general, security testing **cannot guarantee** a system or organization will be **safe from attack**.
What it can do	**Help identify risks** and **evaluate the effectiveness of existing security defenses**.
What supplements it	**Audits and reviews of security practices.**
Due diligence (legal)	It **shows that due diligence has been performed** in protecting digital assets. After a breach, **legal action may result**; if a company can show **reasonable steps** such as **testing for vulnerabilities**, **there may be a defense in a court of law**.
Assurance to clients	It can be **an assurance to clients and customers** that the organization **takes adequate steps to protect sensitive information** — the **confidence and trust** in the LO.

How the official exam used this objective

Sample Q5: after a breach and legal action, how does prior security testing help? **It shows the organization has done due diligence.** Rejected: test documentation to **track down the perpetrator** (probably not helpful); the pre-test **backup to restore** compromised data (likely out of date — and data was stolen or viewed, not necessarily corrupted); **tracing documented tests to discover how the breach happened** (may show where testing fell short, but **does not support the legal defense**). Legal action → **due diligence**.

AS-2.3.1 (K2) — The Organizational Context

Original syllabus statement

Understand how project realities, business constraints, software development lifecycle, and other considerations affect the mission of the security testing team.

- **Security is often one type of functional testing** performed alongside others. With **limited test time**, the **test manager must decide how much testing** — including security testing — can be done.
- Security testing is **often seen as a specialist role** and therefore **outsourced** to a specialist organization.
- **The extent of security testing is ultimately driven by business or organizational risks that are security-based. More security risks → more extensive security testing.**
- **Information security is a lifecycle activity:** needs **defined in requirements, expressed in design, implemented in code**; then testing **verifies and validates** correctness and effectiveness.
- **Security can't be effectively patched into code or tested into code.** Only when security is **built in using secure coding and design techniques** can software be secure.
- **The realities of limited time, resources and scope, along with risk levels, security testing skill sets and lifecycle approaches greatly impact the success of a security testing team.**

The six realities — learn the list

Time · resources · scope · risk levels · skill sets · lifecycle approach. A K2 question on AS-2.3.1 will offer one of these as the answer and three things the syllabus never mentions (tool brand, office location, team size in the abstract).

AS-2.4.1 (K2) — The Alignment of Security Testing Goals

Original syllabus statement

Explain why security testing goals and objectives must align with the organization's security policy and other test objectives in the organization.

The security testing policy can be written once the organization's security policy has been approved by senior management. Security testing goals and objectives, **as expressed in the security testing policy**, must be **in alignment with the overall security policy**. Otherwise **one of two failures** follows:

If goals are not aligned…	…the consequence
Tests go beyond what the security policy authorizes	**Unauthorized security tests will be performed**
Tests do not reflect what the policy actually requires	**Security tests may not achieve the desired purposes**

Order matters: **security policy (senior management) → security testing policy → strategy → approach → tasks**. A question that writes the testing policy before the security policy, or lets a project approach contradict the policy, has the hierarchy backwards (see Chapter 3, Figure 3.1).

AS-2.4.2 (K3) — Identification of Security Test Objectives

Original syllabus statement

For a given project scenario, demonstrate the ability to identify security test objectives based on functionality, technology attributes and known vulnerabilities.

Security test objectives are **like functional test objectives but focused on security goals**. The syllabus gives two rules:

3. **There should be one or more security test objectives for each security feature** of the system or application.
4. Objectives must **also** be based on **attributes of the technology** (e.g. **web, mobile, cloud, LAN**) and **known vulnerabilities** — both **application-specific and generic**.

The syllabus's three example objectives — and the source each comes from

Example objective	Source
Verify that **password authentication applies the correct rule for password strength**	**Functionality** (a security feature)
Verify that **all data entry fields are input validated to prevent SQL injection**	**Known vulnerability** (generic)
Verify that **customer data files are encrypted at the correct strength**	**Technology attribute / asset protection**

How the official exam used this objective (K3, 2 points)

Sample Q7: after an audit found weak passwords, a bank issues new **password strength** requirements. Which are reasonable objectives for **general password rule testing**? Correct set: **length · character, number, letter and capitalization usage · no re-use within a year · reset every three months** (items 1, 2, 4, 5).

Rejected items, per the official rationale: **"passwords can be retried three times"** is **functional rather than security-related** (unless it locks the account — the stem does not say); **"user can request the password by email"** and **"administrator can reset a locked password"** are **functional rather than specific security requirements**.

Technique: keep only items that test **the strength rule itself** (the security feature named in the stem). Strike items about convenience, support workflow or retry counts without a security consequence.

AS-2.4.3 (K2) — Information Assurance versus Security Testing

Original syllabus statement

Understand the relationship between information assurance and security testing.

Term	Definition quoted by the syllabus
Information Assurance (IA)	"**Measures that protect and defend information and information systems by ensuring their availability, integrity, authentication, confidentiality, and non-repudiation.** These measures include providing for **restoration** of information systems by incorporating **protection, detection, and reaction** capabilities." [NISTIR 7298]
Security testing	"**A process used to determine that the security features of a system are implemented as designed and that they are adequate for a proposed application environment.**" [MDA1]

The relationship in one line

IA is the wider, more encompassing term. Security testing is part of IA — as software testing is part of quality assurance. Sample Q6's answer: "**Security testing is a part of information assurance.**" Distractors invert it (IA part of testing), equate them, or call them different areas. Syllabus §0.5 adds that IA is called out **only in section 2.4**, and that the syllabus **does not use the term "cybersecurity"**.

Memory aid — IA's five properties: **A**vailability, **I**ntegrity, **A**uthentication, **C**onfidentiality, **N**on-repudiation ("**AIACN**"), plus restoration through **protection, detection and reaction**.

AS-2.5.1 (K3) — Scope and Coverage of Security Test Objectives

Original syllabus statement

For a given project, demonstrate the ability to define the relationship between security test objectives and the need for strength of integrity of sensitive digital and physical assets.

The greater the need for integrity of sensitive digital and physical assets, the greater the need for coverage of the security test objectives. Security test objectives **essentially describe the scope** of security testing.

If the scope is...	...the syllabus consequence
Too small	**The confidence that security is adequate will not be achieved.**
Too large	**Resources may be depleted before the test can be finished.**

Objectives should describe what testing is expected to achieve in **verifying and validating the protections** for sensitive digital and physical assets, and should **relate directly to specific assets, protective measures, risks and the identification of security vulnerabilities**.

How the official exam used this objective (K3, 2 points)

Sample Q8: after a headline breach, management orders that **the scope of security test objectives be expanded immediately**. The reasonable concern per the syllabus: **the testing scope may be too large and there may not be adequate resources to complete it.** The official rationale notes that "not well-focused" and "objectives not clearly defined" are reasonable worries **but you do not yet know how the objectives will be defined**, so they may be controllable; outsourcing has not been mentioned. When a stem says **scope is being expanded broadly**, answer with **resource depletion**.

§2.6 — Security Testing Approaches: strategy versus approach

The security testing strategy formalizes and communicates an organization's overall direction for security testing. Approaches are then defined that implement the strategy. A security testing approach is **defined at the project level**, must be **consistent with the organization's test policy and strategy**, and is **a unique blend of techniques, tools and skills** to address the project's security test objectives.

AS-2.6.1 (K4) — Analysis of Security Test Approaches

Original syllabus statement

Analyze a given situation and determine which security testing approaches are most likely to succeed.

Each organization has **unique business and mission concerns** requiring unique strategies and approaches, but **some concerns are common** to many organizations. When analyzing a situation to define an approach, consider **thirteen factors**:

#	Factor to consider	#	Factor to consider
1	**The source** of the systems or applications	8	**Common security risks**

#	Factor to consider	#	Factor to consider
2	**Any previous security testing**	9	**The test organization structure**
3	**The security policy**	10	**The project team structure**
4	**The security testing policy**	11	**The test team's experience with security testing tools**
5	**Security risk assessments already performed**	12	**Constraints** — limited resources, time, **lack of access to environments**
6	**The technical environment** — software type and version, frameworks, languages, OS	13	**Assumptions** — e.g. about prior forms of security testing
7	**Security testing skills in the test team**		

Technology changes the approach

- **Different technical environments** (client/server, web, mainframe) **require different approaches**. Development may need **code reviews** for vulnerabilities; testing may need **obfuscation of test data**. **Web applications have different vulnerabilities than mainframes.**
- **Some vulnerabilities are common to multiple technologies** — **buffer overflow** occurs in client-server, web and mobile, differing by **memory management**; the result is the same everywhere: **unpredictable behavior that may let an attacker perform disallowed tasks**.
- **Inadequate data protection can occur anywhere**, but **encryption differs**: web and mobile must protect **data in transit over the Internet**; **in all technologies sensitive data should be stored encrypted**. Example: **The Cattles Group lost two unencrypted backup tapes** with data on about **1.4 million customers** — mainframe data physically shipped unencrypted.

K4 method. Read the scenario, tick off which of the thirteen factors it states, and prefer the approach that **fits the technical environment, uses the skills and tools the team actually has, respects the constraints and builds on existing policy and risk assessment**. An approach that ignores a stated constraint (no environment access, no skills) is the one "least likely to succeed".

AS-2.6.2 (K4) — Analysis of Failures in Security Test Approaches

> **Original syllabus statement**
> Analyze a situation in which a given security testing approach failed, identifying the likely causes of failure.

There are degrees of failure. A vulnerability that is not detected and resolved **does not necessarily mean the approach failed** — there are too many possible vulnerabilities, with **new ones discovered daily**. But some approaches **have been inadequate** and led to compromised assets. **Root cause analysis** identifies why. The syllabus lists **twelve possible causes**, which group naturally:

Group	Possible causes of failure (syllabus list)
Leadership and resources	**Lack of executive leadership** in establishing security testing · **lack of executive provision of resources** (funding, time, resources)
Implementation and skills	**Lack of effective implementation** of the approach (e.g. skills to perform tasks) · **lack of effective tools** · **lack of skills in security testing**
Support	**Lack of organizational understanding and support** · **lack of stakeholder understanding and support**
Alignment	**Lack of alignment with the security policy** · **lack of alignment with the security testing policy and strategy**
Knowledge	**Lack of understanding of security risks** · **lack of understanding of the purpose of the system** · **lack of technical information about the system (causing wrong assumptions)**

> **How the official exam used this objective (K4, 3 points)**

Sample Q9: you inherit sensitive medical-data security; consultants tested before but **nothing was documented, nothing changed, coverage unknown**; executives **agree in principle** but have **allocated no budget or time** and **don't understand what should be done**. First step to align them? **Create a security policy and security testing policy and demonstrate how that aligns with your proposed testing approach.**

Why: the failure causes in the scenario are **lack of executive leadership, lack of executive provision of resources, lack of alignment with policy and strategy**. Without a policy, the official rationale says, **testing may continue to be sporadic and high-level support and funding will be difficult**. Presenting an approach (b) is wrong because **you need an overall policy before you define the approach**; listing every hole (a) or bringing in legal (c) may help **later** if funding stalls.

AS-2.6.3 (K3) — Stakeholder Identification

Original syllabus statement

For a given scenario, demonstrate the ability to identify the various stakeholders and illustrate the benefits of security testing for each stakeholder group.

For a security testing effort to be effective, **a business case must be made to management**, clearly defining **the risks of security lapses** and **the benefits of an effective security testing approach** for the project. **Different stakeholders see different benefits:**

Stakeholder	Benefit they see	Trigger words in a stem
Executive management	**Business protection**	brand, survival, the business as a whole
Senior management	**Due diligence**	legal defense, reasonable steps
Business customers	**Protection from fraud**	fraudulent access, credit cards, their data
Compliance officers (internal corporate security policies)	**Assurance the organization is compliant in terms of legal obligations**	internal policy compliance, legal obligations
Regulatory officers (external security laws)	**Security regulations are being followed**	external law, regulator, regulation
Privacy officers	**Private data is kept secure and due diligence shown** in protecting digital assets	privacy, personal data

How the official exam used this table (K3, 2 points)

Sample Q10: objectives to protect data from **fraudulent access, particularly credit card information**. Which stakeholder group most sees the benefit? **Business customers** — **it is their data that is vulnerable**, and their row is **protection from fraud**. Executives, compliance and regulatory officers should be involved, but **this is not usually their primary benefit**.

AS-2.7.1 (K4) — Improving Security Testing Practices

Original syllabus statement

Analyze KPIs (key performance indicators) to identify security testing practices needing improvement and elements not needing improvement.

To improve, **first evaluate existing practices objectively**, using **key metrics for security testing goals** from which the **degree of success of key strategy elements** can be identified. Practices must be evaluated:

- **From a short-term and a long-term perspective**
- **Considering process and organization**
- **Considering people, tools, systems and techniques**

The four key metrics (KPIs) the syllabus names

KPI	What a weak value suggests
Coverage of security risks by tests	Risk assessment not driving test design; high-risk areas untested
Coverage of security policies and practices by tests	Policies not being verified — the "in place but ineffective" risk is unmanaged
Coverage of security requirements by tests	Traceability gap between requirements and tests
Effectiveness of past security testing, based on **when and where vulnerabilities were identified — both pre- and post-release**	Many **post-release** vulnerabilities, or vulnerabilities found late, indicate the practices that need improvement

K4 method. In a KPI table, a metric that is **high and stable** marks an element **not needing improvement**; one that is **low**, or a high count of **post-release** vulnerabilities in a specific area, marks the practice to improve. Always ask **where** vulnerabilities were found (which phase, which component) — that locates the weak practice. The right answer usually names **both** what to improve **and** what to leave alone, because the LO asks for both.

Section 2 — Key Concepts

Section 1 gives the syllabus wording objective by objective. This section explains what that wording means. Each card builds one idea in order: plain words first, then how it works, an example, how the exam uses it, and what it is easily confused with.

2.1 The storyline of Chapter 2

Chapter 2 answers **"why do we test security, and how do we organize it?"** in a fixed order. **Why** test (to reduce risk and show due diligence) → **what limits** the testing team (time, resources, skills, lifecycle) → **what it must align with** (the security policy, through a chain of documents) → **what to test** (objectives from features, technology and known vulnerabilities) → **how much** (scope grows with the need for integrity) → **how** (a project approach chosen from thirteen factors) → **why approaches fail** (twelve causes) → **who benefits** (six stakeholder groups) → **how to improve** (four KPIs).

Most questions are decided by one of four short lists: **the document hierarchy**, **the three sources of objectives**, **the two scope consequences**, and **the six stakeholder benefits**. The cards below explain each list so that you can work out the answer, not only recognise it.

2.2 What security testing is and why it is needed

How security testing differs from ordinary functional testing	
In plain words	Functional testing checks that the system **does what it should**. Security testing checks that the system **cannot be made to do what it should not**. Its method is to **try to compromise the security policy**, which means behaving like someone who wants to break the rules.
How it works	**Difference 1:** normal ways of choosing test inputs (typical values, boundaries of valid ranges) **may miss security problems**. Attackers use inputs nobody expected, such as SQL fragments, very long strings or script tags. **Difference 2:** the **symptoms** of security defects look different. A functional defect usually shows as a wrong result. A security defect often shows **no visible error at all**: the system works, but data leaks, a log is skipped, or a privilege is wrongly granted. The syllabus lists threats to explore: **unauthorized copying**, **unauthorized access** (doing tasks without the right), **unintended side effects**, **XSS**, **buffer overflow**, **denial of service**, **man in the middle**, **breaking encryption**, and **logic bombs** (code that activates on a condition, such as a date).
Example	The syllabus's **unintended side effect**: a media player plays audio perfectly (so every functional test passes) but writes the decoded files to **unencrypted temporary storage**, where pirates can copy them. No functional test would flag it, because the defect is in what the software does **besides** its job.
Exam angle	Recognise the threat from its description. "Code inserted into a page and run by later users" → **XSS**. "Activates only under certain conditions" → **logic bomb**. "Intercepts and relays while the user is unaware" → **man in the middle**.
Don't confuse	Security testing is **integrated** with all other development and testing activities. It is **not** a separate phase at the end.

The purpose of security testing: risk reduction, due diligence, confidence and trust (AS-2.2.1)	
In plain words	Security testing **cannot guarantee** that a system is safe. What it can do is **find risks** and **check how well the existing defenses work**. As a side effect, it gives the organization **evidence that it behaved responsibly**.
How it works	**Identify risks and evaluate defenses.** This is the direct benefit. It is supplemented by **audits and reviews** of security practices. **Due diligence.** If a breach leads to legal action, an organization that can show it took **reasonable steps**, such as testing for vulnerabilities, **may have a defense in court**. **Assurance to clients.** Customers gain **confidence and trust** that sensitive information is protected.

The purpose of security testing: risk reduction, due diligence, confidence and trust (AS-2.2.1)	
Example	A retailer is breached and sued. Its test reports from the last two years show regular vulnerability testing and fixes. The reports do not undo the breach, but they show the retailer was **not negligent**, which is exactly the due-diligence benefit.
Exam angle	Official Q5: after a breach and a lawsuit, how does earlier security testing help? → **It shows due diligence.** Reject: using test records to **find the attacker**, restoring from the **pre-test backup**, or tracing tests to see **how the breach happened**. None of these supports the **legal** defense.
Don't confuse	**"Cannot guarantee safety"** is always true. An option that promises security testing makes a system secure is wrong.

What shapes the security testing team's mission (AS-2.3.1)	
In plain words	The security test team never works in ideal conditions. **How much** it can test, and how well, depends on the realities of the project and the organization.
How it works	**The six realities** the syllabus names: **limited time, resources and scope**, plus **risk levels**, **security testing skill sets**, and the **lifecycle approach**. **The extent of security testing is driven by security-based business risk.** More risk means more testing. Security is often treated as **one type of functional testing**, competing for limited test time. The **test manager decides how much** is done. It is often seen as a **specialist role** and **outsourced**. **Security cannot be patched or tested into code.** It must be **built in** through secure design and coding. Testing then **verifies and validates** it.
Example	A two-week sprint has three days of testing. The team has no penetration tester, and the product handles card data. The realities are **time** (3 days), **skills** (none in-house) and **risk** (high). So the manager outsources a focused test of the payment flow, and the team runs scripted checks on the rest.
Exam angle	A K2 question gives one of the six realities among options the syllabus never mentions (office location, tool brand, team morale). Choose the reality.
Don't confuse	"Security can't be tested into code" does **not** mean testing is useless. It means testing **confirms** security that was **designed and built in**, and cannot add it afterwards.

2.3 Alignment, objectives and scope

The document hierarchy and why alignment matters (AS-2.4.1)	
In plain words	Security testing is governed by a **chain of documents**, each written from the one above it: **security policy → security testing policy → security test strategy → security test approach → security test tasks.** If a lower level does not match the level above, testing goes wrong in one of two ways.
How it works	**Security policy**: the organization's security rules, **approved by senior management**. It comes first. **Security testing policy**: written **once the security policy is approved**, and **aligned** with it. It states the goals and objectives of security testing. **Strategy** (organization level): the overall direction for security testing. **Approach** (project level): how one project implements the strategy. **Tasks**: the actual work. **Failure 1:** testing goes beyond what the policy authorizes → **unauthorized security tests are performed**. **Failure 2:** testing does not reflect what the policy requires → **tests do not achieve their purpose**.
Example	A project team decides on its own to run a phishing simulation against all staff. The security policy does not authorize social-engineering tests, so this is an **unauthorized test**, even though the intent is good. The opposite case: the policy requires card data to be encrypted at rest, but the test plan only covers login screens, so the tests **miss their purpose**.

The document hierarchy and why alignment matters (AS-2.4.1)	
Exam angle	If a scenario shows testing that is **sporadic, unfunded and uncoordinated**, the fix is at the **top of the chain**. Official Q9 (3 points): **create a security policy and a security testing policy, and show how the proposed approach aligns with them.** Presenting an approach first is wrong, because there is no policy to anchor it.
Don't confuse	**Organizational level** = policy and strategy. **Project level** = approach and tasks. An option that puts the approach at organizational level, or writes the testing policy before the security policy, has the hierarchy backwards.

Where security test objectives come from (AS-2.4.2, guaranteed K3)	
In plain words	A security test objective states **what a security test should confirm**. The syllabus gives **three sources** for objectives, and a good set uses all three.
How it works	**Functionality**: **at least one objective per security feature** of the system (login, password rules, encryption, audit logging…). **Technology attributes**: the kind of technology brings its own risks (**web, mobile, cloud, LAN**). **Known vulnerabilities**: both **generic** (SQL injection, XSS) and **application-specific** (a flaw found in an earlier release).
Example	The syllabus's three examples map to the three sources: "password authentication applies the **correct strength rule**" (a feature), "all data entry fields are **validated against SQL injection**" (a known generic vulnerability), and "customer data files are **encrypted at the correct strength**" (asset protection and technology).
Exam angle	Official Q7 (2 points): from a list, keep only the items that test the **security rule named in the stem**. For password-strength rules: **length**, **character mix**, **no re-use within a year** and **change every three months** are security. **Retry three times** (with no lockout), **email the password on request** and **admin can reset** are **functional** items. **Method:** for each candidate, ask "does this check the **strength or protection** the stem is about, or is it a **convenience or support workflow**?"
Don't confuse	A retry limit becomes a security objective only when it **locks the account** (a lockout control). A bare retry count is functional. Read the stem for the consequence.

Information assurance vs security testing (AS-2.4.3)	
In plain words	**Information assurance (IA)** is the **whole effort** to protect information and systems. **Security testing is one part of it**, in the same way that software testing is one part of quality assurance.
How it works	**IA** (NISTIR 7298): measures that protect and defend information and systems by ensuring **availability, integrity, authentication, confidentiality and non-repudiation**, including **restoration** through **protection, detection and reaction** capabilities. **Security testing**: a process to determine that **security features are implemented as designed** and are **adequate** for the proposed environment. **Relationship:** IA is the wider term. Security testing is a part of IA.
Example	A bank's IA programme includes policies, staff vetting, encryption, backups, incident response and security testing. The tests check that encryption and access controls really work. That is the testing **part** of the assurance picture.
Exam angle	Official Q6: "**Security testing is a part of information assurance.**" Reject options that say IA is part of testing, that the two are the same, or that they are unrelated.
Don't confuse	IA has **five** properties: CIA (**confidentiality, integrity, availability**) **plus authentication and non-repudiation**. Do not shorten it to the CIA triad.

Scope, coverage and the need for integrity (AS-2.5.1, guaranteed K3)	
In plain words	The **more important it is that an asset stays correct and protected**, the **more of it your security test objectives must cover**. The objectives **are** the scope: they say what testing will look at. Getting the size of that scope right is a balance.
How it works	**Rule:** greater need for **integrity** of sensitive digital and physical assets → greater need for **coverage** by the security test objectives. **Scope too small → the confidence that security is adequate will not be achieved.** **Scope too large → resources may be depleted before the test can be finished.** Objectives should relate **directly to specific assets, protective measures, risks and the identification of vulnerabilities**.
Example	A hospital tests its patient-prescription module (high integrity need: a changed dose can kill) much more thoroughly than its cafeteria-menu page. If management suddenly orders "test everything to the same depth", the team will run out of time before finishing, and the prescription module may end up **less** tested than before.
Exam angle	Official Q8: management orders the scope to be **expanded immediately** after a breach in the news. The reasonable concern → **the scope may be too large, and there may not be enough resources to complete it.** "Objectives not well-focused" is a possible worry but not yet known. **Broad expansion → resource depletion.**
Don't confuse	**Too small** costs **confidence**. **Too large** costs **resources**. Exam options often swap the two consequences.

2.4 Approaches, failures, stakeholders and improvement

Strategy vs approach, and the thirteen factors that shape an approach (AS-2.6.1)	
In plain words	The **strategy** is the organization's overall direction for security testing. An **approach** is how **one project** puts that strategy into practice: a **unique blend of techniques, tools and skills** that fits that project. To choose the blend, look at the project's situation through thirteen factors.
How it works	**What already exists:** the **source** of the system (in-house, vendor, open source), **previous security testing**, the **security policy**, the **security testing policy**, and **risk assessments already performed**. **The technology:** the **technical environment** (software type and version, frameworks, languages, OS) and the **common security risks** for it. **The people and organization: security testing skills** in the team, the **test organization structure**, the **project team structure**, and the team's **experience with security tools**. **The limits: constraints** (resources, time, **no access to environments**) and **assumptions** (for example, about earlier testing). **Technology changes the approach.** Web applications have different vulnerabilities from mainframes. Some (buffer overflow, poor data protection) occur everywhere, but they show up differently.
Example	Project A is a vendor-supplied web portal with no source code, a team experienced with web scanners, and no access to production. The approach is black-box web scanning plus manual tests in a copy of the environment, with **no code review** (there is no code). Project B is an in-house mainframe batch system: code reviews, test-data obfuscation, and checks that backup tapes are encrypted (the syllabus's Cattles Group lost 1.4 million records on unencrypted tapes).
Exam angle	For "which approach is **most likely to succeed**?", tick off the factors the scenario states. The best approach **fits the technology, uses the skills and tools the team actually has, respects the stated constraints, and builds on existing policy and risk assessments**. An approach that ignores a stated constraint is the one likely to fail.
Don't confuse	**Strategy = organization, approach = project.** The approach must be **consistent with** the policy and strategy. It cannot replace them.

Why security test approaches fail (AS-2.6.2, a K4 pool)	
In plain words	One missed vulnerability does **not** prove the approach failed, because nobody can find every vulnerability. There are **degrees of failure**. When an approach really was inadequate, **root cause analysis** finds out why. The syllabus lists twelve possible causes.
How it works	**Leadership and money:** lack of **executive leadership** · lack of **executive provision of resources** (funding, time, people). **Doing the work:** lack of **effective implementation** · lack of **effective tools** · lack of **security testing skills**. **Support:** lack of **organizational** understanding and support · lack of **stakeholder** understanding and support. **Alignment:** lack of alignment with the **security policy** · lack of alignment with the **security testing policy and strategy**. **Knowledge:** lack of understanding of **security risks** · of **the purpose of the system** · lack of **technical information** about the system, which leads to wrong assumptions.
Example	The syllabus's Q9 scenario: consultants tested once, documented nothing, nothing changed, and coverage is unknown. Executives agree "in principle" but give no budget or time and do not understand what is needed. The causes are **no leadership, no resources and no policy alignment**. The first remedy is therefore a **policy and testing policy**, with the approach shown to align with them.
Exam angle	Map each symptom to its cause group, then pick the remedy that addresses the **earliest** cause in the chain (policy and leadership before tools and skills). Listing every hole or calling in lawyers may help **later**, but they are not the first step.
Don't confuse	"A vulnerability was found in production" on its own is **not** evidence that the approach failed. Look for **systemic** causes.

Six stakeholder groups, six benefits (AS-2.6.3, guaranteed K3)	
In plain words	To get support and money for security testing you must make a **business case**, and different people value **different benefits**. Learn each group with its one benefit.
How it works	**Executive management** → **business protection** (the survival and brand of the whole business). **Senior management** → **due diligence** (evidence of reasonable steps). **Business customers** → **protection from fraud** (it is **their** data and money at risk). **Compliance officers** (internal corporate security policies) → **assurance the organization meets its legal obligations**. **Regulatory officers** (external security laws) → **assurance that security regulations are being followed**. **Privacy officers** → **private data is kept secure**, and due diligence is shown in protecting digital assets.
Example	A test objective is to protect stored credit-card numbers from fraudulent access. Executives, compliance and regulators all care, but the group that **most directly benefits** is the **business customers**, because their cards would be used fraudulently.
Exam angle	Official Q10: fraud and credit cards → **business customers**. **Find the stakeholder whose benefit names the concern in the stem**, not the stakeholder who is merely involved.
Don't confuse	**Executive** (business protection) ≠ **senior** (due diligence). The syllabus keeps them separate. **Compliance officers** look at **internal** policies and legal obligations. **Regulatory officers** look at **external** regulations. **Due diligence** appears for both senior management and privacy officers. If the stem is about **personal data**, choose **privacy officers**.

Improving security testing with KPIs (AS-2.7.1, a K4 pool)	
In plain words	To improve, first **measure** how well current practices work, honestly and objectively. The syllabus names **four key metrics**, and you judge each practice **short-term and long-term**, considering **process and organization**, and **people, tools, systems and techniques**.
How it works	**Coverage of security risks** by tests. **Coverage of security policies and practices** by tests. **Coverage of security requirements** by tests. **Effectiveness of past security testing**, based on **when and where** vulnerabilities were found, **before and after release**.
Example	A KPI report shows 95% of security requirements covered, but 40% of high risks untested, and most production vulnerabilities in one payments component. **Leave alone:** requirements traceability (it is working). **Improve:** risk-based test design, and testing of the payments component.
Exam angle	The LO asks for practices **needing** improvement **and** elements **not needing** improvement. The best option usually names both. A **high and stable** metric is not where to act. **Many post-release vulnerabilities in one area** point to the practice to fix.
Don't confuse	Coverage of **requirements** is not coverage of **risks**. A team can trace every requirement and still miss high risks that no requirement mentions.

2.5 Fuzzy points clarified

Places where the wording is easy to misread

"Security policy", "security testing policy" and "test policy" are three different documents. The security policy is the organization's security rules. The security testing policy states how security testing supports them. The general test policy covers all testing. The thirteen approach factors list the first two separately.

"Strategy" is organization-level, but the syllabus also says the approach must be "consistent with the test policy and strategy". This is not a contradiction: the approach is **derived from** the strategy, for one project.

The "what a weak value suggests" column of the KPI table, and the K4 KPI method in Section 1, are this guide's interpretation. The syllabus names only the four metrics and the perspectives (short/long term; process and organization; people, tools, systems, techniques).

Q7's retry item is functional only because the stem says nothing about lockout. If a stem adds "and then the account is locked", the same item becomes a security objective (a lockout control, Chapter 3).

IA appears only in §2.4 of the syllabus, and the syllabus deliberately does not use the word "cybersecurity". If an option uses "cybersecurity", judge it by its content, not by the word.

2.6 Chapter 2 keyword glossary

Keyword	Working definition for the exam
cross-site scripting	Code inserted into a web page that may be exercised by subsequent users; may be malicious.
data obfuscation	Making data non-understandable to humans — here named as something **testing may require** for test data (detail in Chapter 5).
denial of service	Preventing users from interacting with an application, e.g. by overloading a server with nuisance requests.
information assurance	Measures that protect and defend information and systems by ensuring availability, integrity, authentication, confidentiality and non-repudiation — **broader than security testing**.
security policy	The organization's approved statement of security principles; the **security testing policy is aligned to it**.
security testing	A process to determine that security features are **implemented as designed** and **adequate** for the proposed environment.

Keyword	Working definition for the exam
security vulnerability	A weakness that could be exploited by a threat source.
software lifecycle	The framework within which security needs are defined, designed, implemented and tested — security is a lifecycle activity.
test strategy	The organization's overall direction for (security) testing, implemented through project-level approaches.

Section 3 — Tables and Summaries

3.1 The chapter on one page

Topic	What to remember	LO
Purpose	Cannot guarantee safety · identify risks · evaluate defenses · **due diligence** · assurance	AS-2.2.1
Context	Risk drives extent · specialist/outsourced · lifecycle · time, resources, scope, risk, skills, lifecycle	AS-2.3.1
Alignment	Security policy → testing policy; else unauthorized tests or missed purposes	AS-2.4.1
Objectives	≥1 per security feature + technology attributes + known vulnerabilities	AS-2.4.2
IA	IA ⊃ security testing (QA ⊃ testing)	AS-2.4.3
Scope	More integrity need → more coverage; too small = no confidence, too large = resources depleted	AS-2.5.1
Approaches	13 situational factors; technology drives approach	AS-2.6.1
Failures	Degrees of failure; root cause analysis; 12 causes	AS-2.6.2
Stakeholders	Six groups, six benefits; business case	AS-2.6.3
KPIs	Coverage of risks / policies / requirements; effectiveness pre- and post-release	AS-2.7.1

3.2 Stakeholder → benefit (the K3 decider)

Stakeholder	Benefit
Executive management	Business protection
Senior management	Due diligence
Business customers	Protection from fraud
Compliance officers (internal policies)	Compliant with legal obligations
Regulatory officers (external laws)	Regulations being followed
Privacy officers	Private data secure; due diligence in protecting digital assets

3.3 Security vs functional objective — the Q7 filter

Candidate objective	Security?	Why
Password length enforced	**Yes**	Strength rule
Mixed character classes enforced	**Yes**	Strength rule
No re-use within a year	**Yes**	Strength / history rule
Reset every three months	**Yes**	Strength / ageing rule
Password can be retried three times	No†	Functional — unless it locks the account
Password can be emailed on request	No	Functional support workflow
Admin can reset a locked password	No	Functional support workflow

† Retry-then-lockout is a security control (Chapter 3); a bare retry count is not.

3.4 Failure cause → remedy

Observed in the scenario	Likely cause	First remedy
Executives agree “in principle” but fund	Lack of executive leadership / provision of	**Policy + testing policy + business case**

Observed in the scenario	Likely cause	First remedy
nothing	resources	
Tests run, nobody acts on findings	Lack of organizational / stakeholder support	Stakeholder benefits, business case
Consultants tested the wrong things	Lack of alignment with policy and strategy; lack of understanding of risks	Align objectives to policy and risk assessment
Wrong assumptions about architecture	Lack of technical information about the system	Obtain design and environment information
Team can't run the scanner	Lack of skills / effective tools	Training, tool selection (Chapter 8)

Reproduce from memory before moving on

Table 3.2 — six stakeholders, six benefits (guaranteed 2 points).

The scope rule — too small / too large (guaranteed 2 points).

Objective sources — feature, technology attribute, known vulnerability, and the security-vs-functional filter (guaranteed 2 points).

Policy first — the hierarchy and the twelve failure causes (likely 3 points).

Section 4 — Demo Questions with Answers

*Questions 1–6 are the **official ISTQB CTAL-SEC Sample Exam questions for Chapter 2** — #5 to #10 — with their official answers and rationale. LO tags are inferred (the GA sample exam removed them) and match the Exam Structure Table. Questions 7–26 are derived strictly from the syllabus text. Correct options are marked ✔.*

Part A — The 6 official Chapter 2 questions

Q1. OFFICIAL · Sample Exam #5 (1 pt)

If an organization experiences a security breach and legal action results, how does it help the organization to have done security testing?

a) It can show that the organization has done due diligence to try to prevent such an incident ✔

b) The documentation from the security testing can be used to track down the perpetrator

c) Since any important information would have been backed up before security testing, this backup can be used to restore any compromised information

d) By tracing through the documented tests, the security testing team can discover how the breach was possible

Correct answer: a | LO: AS-2.2.1 (K2) | Syllabus §2.2

Why: (a) — official rationale: **correct per the syllabus**. (b) **this information would probably not be helpful**. (c) **the backup would likely be out of date and the information was not necessarily corrupted, but rather stolen or viewed**. (d) **may help point to areas where testing was not sufficient, but it will not support the organization's defense of legal actions**. Syllabus §2.2: **if a company can show that it took reasonable steps to protect digital assets, such as testing for vulnerabilities, there may be a defense in a court of law**.

Q2. OFFICIAL · Sample Exam #6 (1 pt)

Which of the following is a correct statement?

a) Information assurance is a part of security testing

b) Information assurance and security testing are two terms for the same thing

c) Security testing is a part of information assurance ✔

d) The two terms refer to different areas of security

Correct answer: c | LO: AS-2.4.3 (K2) | Syllabus §2.4.3

Why: (c) — official rationale: **security testing is a part of the larger area of information assurance**. Syllabus §2.4.3: **IA is a wider, more encompassing term. This relationship is similar to that between Quality Assurance (QA) and Software Testing.**

Q3. OFFICIAL · Sample Exam #7 (2 pts)

You are working at a bank as part of the security testing team. During a recent security audit it was noted that the user's passwords were not strong enough. Since that time, a new set of requirements has been issued to ensure password strength. Given this information, what would be a reasonable set of security objectives for general password rule testing?

1. Verify that passwords meet the requirements for length
2. Verify that passwords meet the requirements for usage of characters, numbers, letters and capitalization
3. Verify that passwords can be retried three times
4. Verify that passwords cannot be re-used within a one year timeframe
5. Verify that passwords must be reset every three months
6. Verify that the user can request to have their password emailed to them
7. Verify that the system administrator can reset a locked password

a) 1, 2, 3, 4
b) 1, 2, 4, 5 ✔
c) 3, 4, 6, 7
d) 4, 5, 6, 7

Correct answer: b | LO: AS-2.4.2 (K3) | Syllabus §2.4.2

Why: (b) — official rationale: **all of these are valid security objectives**. (a) is wrong because **3 is functional rather than security-related (unless it locks them out, but we don't know that from this description)**. (c) is wrong because **6 and 7 are both functional rather than specific security requirements**; (d) for the same reason. Syllabus §2.4.2: objectives focus on **security goals** — e.g. **verify that password authentication applies the correct rule for password strength**.

Q4. OFFICIAL · Sample Exam #8 (2 pts)

Your company recently made headlines after a security breach resulted in confidential customer information being stolen. Management has reacted with an edict that the scope of the security testing objectives needs to be expanded immediately. While you agree that something needs to be done, you are worried that this approach may be too reactive and may not result in the testing that is needed.

According to the syllabus, what is a reasonable concern if these initiatives are implemented?

a) The testing will still miss issues because it will not be well-focused
b) The testing will be outsourced so that it can be done more efficiently
c) The testing scope may be too large and there may not be adequate resources to complete it ✔
d) The testing objectives are not clearly defined and may miss the same issues as previously escaped to production

Correct answer: c | LO: AS-2.5.1 (K3) | Syllabus §2.5

Why: (c) — official rationale: **correct per the syllabus as this is a common problem when the objectives are broadly defined**. (a) and (d) **are reasonable concerns, but you don't know when or how the test objectives will be defined, so this may be controllable**. (b) **is always a possibility ... but there has been no indication that outsourcing will occur**. Syllabus §2.5: **if the scope is too large, resources may be depleted before the test can be finished**.

Q5. OFFICIAL · Sample Exam #9 (3 pts)

You have just accepted a job to create a security testing team for a company that handles sensitive medical information that is shared between doctors and hospitals. You have noticed that the security around this information is not sufficient to protect it from hackers or even accidental exposure. The person who had your job previously brought in a number of consultants to do testing, but the findings were not documented and no changes were implemented. In fact, you don't even know what the coverage was from the testing. You have presented your findings to the executive management team. While they have agreed in principle that they need security testing, they have not allocated the necessary budget or time to the project. It appears that while they think security is a good idea, they really have no understanding of what should be done or how it should be done. What should be your first step toward getting the executives aligned with the work that needs to be done?

a) Create a detailed list of all the possible security holes and present these to the executives

b) Provide a summary of the testing approach that you propose and give examples of how the testing will be conducted

c) Bring in the legal team to explain what a security breach could cost the organization

d) Create a security policy and security testing policy and demonstrate how that aligns with your proposed testing approach ✔

Correct answer: d | LO: AS-2.6.2 (K4) | Syllabus §2.4.1, §2.6.2

Why: (d) — official rationale: **at this point, the organization needs a high level policy and plan to move forward. Without this policy, the testing may continue to be sporadic and high level support and funding will be difficult.** (a) and (c) **might be useful if you have trouble getting funding when you work to implement the policy**. (b) **is not right because you need an overall policy before you define the approach**. The scenario exhibits the failure causes **lack of executive leadership**, **lack of executive provision of resources** and **lack of alignment with policy and strategy** (§2.6.2).

Q6. OFFICIAL · Sample Exam #10 (2 pts)

You have just come from a meeting where there was much discussion regarding the security approach of the organization. One of the points of emphasis was the importance of testing to ensure that data is protected from fraudulent access, particularly credit card information. You have been asked to prepare a set of testing objectives that will help address this risk area. One of your tasks is to ensure that you are covering all the concerns of the stakeholders. Which stakeholder group is most likely to see the benefits from your efforts?

a) Executive management

b) Compliancy officers

c) Business customers ✔

d) Regulatory officers

Correct answer: c | LO: AS-2.6.3 (K3) | Syllabus §2.6.3

Why: (c) — official rationale: **the business customers will be most concerned with protection from fraudulent access as it is their data that is vulnerable**. You would hope (a), (b) and (d) are also involved, **but this is not usually their primary benefit**. Syllabus §2.6.3: **business customers may see protection from fraud**.

Part B — 20 additional syllabus-derived questions

*The K-level in each question's label is the level of the **learning objective** it practises, not of the question itself. Some Part B items are quick recall checks on a K3 or K4 objective. Use them to learn the facts, and use the scenario items (and Part A) to practise the reasoning the real K3/K4 questions need.*

Q7. Derived from syllabus

Which statement about the purpose of security testing is correct?

a) Security testing, if performed thoroughly, guarantees the organization will be safe from attack

b) Security testing can help identify risks and evaluate the effectiveness of existing security defenses, and is supplemented by audits and reviews ✔

c) Security testing replaces the need for security audits

d) Security testing is only needed when an organization handles credit card data

Correct answer: b | LO: AS-2.2.1 (K2) | Syllabus §2.2

Why: (b). Syllabus §2.2: **security testing cannot guarantee a system or organization will be safe from attack. However, security testing can help identify risks and evaluate the effectiveness of existing security defenses. There are other activities to supplement security testing, such as audits and reviews of security practices.**

Q8. Derived from syllabus

A sales director asks how security testing benefits the relationship with clients. Which answer reflects the syllabus?

a) It allows the organization to publish its vulnerability list for transparency

b) It removes the need to encrypt client data

c) It guarantees clients will never suffer a breach

d) It can be an assurance to clients and customers that the organization takes adequate steps to protect sensitive information ✔

Correct answer: d | LO: AS-2.2.1 (K2) | Syllabus §2.2

Why: (d) is the syllabus wording — the **higher levels of confidence and trust** named in the LO. (a) contradicts the confidentiality of security results (Chapter 7). (c) is never claimed.

Q9. Derived from syllabus

What ultimately drives the extent of security testing in an organization?

a) Business or organizational risks that are security-based ✔

b) The number of security testers available

c) The number of open source security tools available

d) The length of the release cycle

Correct answer: a | LO: AS-2.3.1 (K2) | Syllabus §2.3

Why: (a). Syllabus §2.3: **the extent of security testing is ultimately driven by business or organizational risks that are security-based. When security risks are numerous in an organization, more extensive security testing is needed.** (b) and (d) are realities that affect success, not what drives extent.

Q10. Derived from syllabus

A project manager proposes to “add security at the end” by running a penetration test before go-live and patching whatever it finds. Which syllabus statement best explains why this is weak?

a) Penetration tests are illegal without a court order

b) Security testing is always outsourced, so the project cannot schedule it

c) Security can’t be effectively patched into code or tested into code; it must be built in using secure coding and design techniques ✔

d) Penetration testing does not find vulnerabilities in web applications

Correct answer: c | LO: AS-2.3.1 (K2) | Syllabus §2.3

Why: (c). Syllabus §2.3: **information security is a lifecycle activity ... Security can’t be effectively patched into code or tested into code. Only when security is built into software using secure coding and design techniques can software be secure.**

Q11. Derived from syllabus

Which list contains only factors the syllabus says greatly impact the success of a security testing team?

a) Office location, programming language, team size

b) Limited time, resources and scope; risk levels; security testing skill sets; lifecycle approaches ✔

c) Tool vendor, licence type, test management tool

d) Number of stakeholders, number of releases, number of defects

Correct answer: b | LO: AS-2.3.1 (K2) | Syllabus §2.3

Why: (b) — verbatim from §2.3: **the realities of limited time, resources and scope, along with risk levels, security testing skill sets and lifecycle approaches greatly impact the success of a security testing team**.

Q12. Derived from syllabus

Why must security testing goals and objectives align with the organization's security policy?

a) Otherwise either unauthorized security tests will be performed, or security tests may not achieve the desired purposes ✔

b) Because the security policy defines which tools may be purchased

c) Because the security testing policy must be approved before the security policy

d) Otherwise the test manager cannot estimate effort

Correct answer: a | LO: AS-2.4.1 (K2) | Syllabus §2.4.1

Why: (a) — verbatim from §2.4.1. (c) inverts the order: **the security testing policy can be written once the organization's security policy has been approved by senior management**.

Q13. Derived from syllabus

When can the security testing policy be written?

a) Before the security policy, so that the security policy can reference it

b) At any time, since the two documents are independent

c) After the first penetration test has been performed

d) Once the organization's security policy has been approved by senior management ✔

Correct answer: d | LO: AS-2.4.1 (K2) | Syllabus §2.4.1

Why: (d) — syllabus §2.4.1.

Q14. Derived from syllabus

A retailer is building a mobile app that stores loyalty-card numbers on the device and calls a cloud API to redeem points. Security features specified: login with PIN, session timeout after 5 minutes, and encrypted local storage.

Which set of security test objectives best follows the syllabus's guidance on identifying objectives?

a) Verify that the app loads within 2 seconds; verify that the loyalty balance is correct

b) Verify that the PIN login works; verify that points can be redeemed

c) Verify that the PIN rule is enforced and sessions time out after 5 minutes; verify that locally stored card numbers are encrypted at the correct strength; verify that API inputs are validated against known injection vulnerabilities; verify protection of data in transit for the mobile-to-cloud call ✔

d) Verify that all OWASP tests are executed against every screen

Correct answer: c | LO: AS-2.4.2 (K3) | Syllabus §2.4.2

Why: (c) has **one or more objectives for each security feature** (PIN, timeout, encrypted storage), plus objectives from **technology attributes** (mobile, cloud — data in transit) and **known vulnerabilities** (injection). (a) and (b) are functional/performance objectives. (d) is not tied to features, technology or specific vulnerabilities, and risks an unbounded scope.

Q15. Derived from syllabus

According to the syllabus, how many security test objectives should exist for each security feature of a system?

a) Exactly one

b) One or more ✔

c) At least three, one per CIA property

d) None — objectives are defined per risk, not per feature

Correct answer: b | LO: AS-2.4.2 (K3) | Syllabus §2.4.2

Why: (b). §2.4.2: **there should be one or more security test objectives for each security feature of the system or application.**

Q16. Derived from syllabus

Which of the following is part of the NISTIR 7298 definition of information assurance quoted in the syllabus?

a) Ensuring availability, integrity, authentication, confidentiality and non-repudiation, including restoration through protection, detection and reaction capabilities ✔

b) Determining that security features are implemented as designed and adequate for a proposed application environment

c) Testing the system's vulnerability to threats by attempting to compromise its security policy

d) A manual examination that identifies weaknesses in security processes and infrastructure

Correct answer: a | LO: AS-2.4.3 (K2) | Syllabus §2.4.3

Why: (a) is IA. (b) is the **security testing** definition [MDA1]. (c) is the §2.1 description of what security testing does. (d) is the definition of a **security audit** (Chapter 1).

Q17. Derived from syllabus

Two systems are being tested by the same team: (1) an internal cafeteria menu site and (2) a hospital system storing patient diagnoses and prescriptions. The team has a fixed budget.

How should the coverage of security test objectives be set?

a) Equal coverage for both, to be fair to both product owners

b) More coverage for the menu site, because it is Internet-facing

c) Coverage determined by the number of screens in each system

d) More coverage for the hospital system, because the greater the need for integrity of sensitive assets, the greater the need for coverage — while keeping scope within the resources available ✔

Correct answer: d | LO: AS-2.5.1 (K3) | Syllabus §2.5

Why: (d). §2.5: **the greater the need for integrity of sensitive digital and physical assets, the greater the need is for coverage of the security test objectives**; objectives **relate directly to specific assets, protective measures, risks and vulnerabilities**; and **too large a scope depletes resources**.

Q18. Derived from syllabus

A security test plan restricts objectives to the login page of a payments platform "to finish on time". What is the syllabus's concern?

a) If the scope is too small, the confidence that security is adequate will not be achieved ✔

b) If the scope is too small, resources will be depleted

c) A small scope always produces more false positives

d) Login pages are out of scope for security testing

Correct answer: a | LO: AS-2.5.1 (K3) | Syllabus §2.5

Why: (a). §2.5: **if the scope is too small, the confidence that security is adequate will not be achieved. If the scope is too large, resources may be depleted before the test can be finished.** (b) swaps the two consequences.

Q19. Derived from syllabus

A bank must security-test a 30-year-old COBOL mainframe batch system that exchanges files with partners on tape and over SFTP. The test team is skilled in web application scanning tools but has no mainframe experience. There is no separate mainframe test environment, and nightly production batch windows cannot be disturbed.

Which approach is most likely to succeed?

a) Run the team's web vulnerability scanner against the mainframe's production IP address during the batch window

b) Skip security testing, because mainframes have no vulnerabilities

c) Tailor an approach to the mainframe environment: involve people with mainframe skills, focus on data protection at rest and in transit (including whether partner files and tapes are encrypted), review access rights and code where possible, and plan around the environment constraint rather than testing in production ✔

d) Reuse last year's web-application test approach unchanged to save time

Correct answer: c | LO: AS-2.6.1 (K4) | Syllabus §2.6.1

Why: (c) respects the syllabus factors: **technical environment** (different environments **require different approaches**; mainframes differ from web), **skills in the team**, **constraints such as lack of access to environments**, and the **data protection** point — **sensitive data should be stored encrypted in all technologies**, with the **Cattles Group lost-tapes** example. (a) ignores constraints and environment; (b) is false; (d) ignores the technical environment.

Q20. Derived from syllabus

Which statement about vulnerabilities across technologies is consistent with the syllabus?

a) Buffer overflows only occur in mainframe systems

b) Buffer overflows can occur in client-server, web and mobile applications, with differences based on memory management, but the result is the same: unpredictable behavior that may let an attacker perform disallowed tasks ✔

c) Encryption algorithms for web and mainframe environments must always be different

d) Data in transit only needs protection in mainframe environments

Correct answer: b | LO: AS-2.6.1 (K4) | Syllabus §2.6.1

Why: (b) — §2.6.1. On encryption, the syllabus says the **algorithms may be the same (or similar)**; the difference is that **web and mobile must protect data in transit over the Internet**.

Q21. Derived from syllabus

A security test approach for a new portal used a commercial scanner configured by a contractor. The scanner's report was clean, but within a month an attacker exploited a business-logic flaw in the checkout. Post-incident review finds: the contractor was never given the architecture documents and assumed a single-tier design; nobody on the internal team could interpret the scanner configuration; the security testing policy required manual testing of business logic but the approach did not include it.

Which causes of failure are most clearly evidenced?

a) Lack of technical information about the system (wrong assumptions), lack of skills in security testing, and lack of alignment between the approach and the security testing policy ✔

b) Lack of executive leadership and lack of funding

c) Lack of effective tools only — the scanner was inadequate

d) No failure occurred, because one vulnerability does not mean the approach failed

Correct answer: a | LO: AS-2.6.2 (K4) | Syllabus §2.6.2

Why: (a) maps each observation to a syllabus cause: no architecture documents → **lack of technical information about the system (causing wrong assumptions)**; nobody could interpret the configuration → **lack of skills**; policy required logic testing but approach omitted it → **lack of alignment with the security testing policy and strategy**. (d) misapplies "degrees of failure": here the approach demonstrably missed what policy required, and assets were compromised.

Q22. Derived from syllabus

What technique does the syllabus recommend to identify why a security testing approach may have failed?

a) A new penetration test

b) A customer survey

c) Root cause analysis ✔

d) A static code review

Correct answer: c | LO: AS-2.6.2 (K4) | Syllabus §2.6.2

Why: (c). §2.6.2: **root cause analysis can help identify why a security testing approach may have failed.**

Q23. Derived from syllabus

A security test program for a health insurer is shown to demonstrate that patient records are protected and that reasonable steps have been taken to safeguard them. Which stakeholder group is this benefit most directly aimed at?

a) Executive management

b) Business customers

c) Regulatory officers

d) Privacy officers ✔

Correct answer: d | LO: AS-2.6.3 (K3) | Syllabus §2.6.3

Why: (d). §2.6.3: **privacy officers may see the benefit that private data is kept secure and due diligence has been shown in the protection of digital assets**.

Q24. Derived from syllabus

Which pairing of stakeholder and benefit is correct according to the syllabus?

a) Executive management — protection from fraud

b) Compliance officers — assurance that the organization is compliant in terms of legal obligations ✔

c) Business customers — due diligence

d) Regulatory officers — business protection

Correct answer: b | LO: AS-2.6.3 (K3) | Syllabus §2.6.3

Why: (b). The correct pairings: executive management → **business protection**; senior management → **due diligence**; business customers → **protection from fraud**; compliance officers → **compliant with legal obligations** (internal policies); regulatory officers → **regulations being followed** (external laws); privacy officers → **private data secure**.

Q25. Derived from syllabus

KPIs for the last four releases: coverage of security requirements by tests 96–98%; coverage of security policies by tests 95%; coverage of identified security risks by tests 52–58%. Vulnerabilities found: pre-release 40, 38, 41, 39; post-release (production) 9, 11, 12, 14 — all post-release vulnerabilities were in areas rated high-risk in the risk assessment but without linked tests.

Which conclusion best follows from the KPIs?

a) Risk-based test coverage needs improvement — high-risk areas lack tests and post-release vulnerabilities are rising there; requirement and policy coverage do not need improvement ✔

b) Requirement coverage needs improvement because it is below 100%

c) Everything is fine because pre-release vulnerability counts are stable

d) Policy coverage is the weakest area and should be the focus

Correct answer: a | LO: AS-2.7.1 (K4) | Syllabus §2.7

Why: (a). The syllabus measures **coverage of security risks, of policies and practices, and of requirements by tests**, and **effectiveness based on when and where vulnerabilities were identified, pre- and post-release**. Risk coverage is low and post-release escapes cluster in **untested high-risk areas** and are **increasing** — that is the practice to improve. Requirement and policy coverage are high and stable — **elements not needing improvement**, which the LO explicitly asks you to identify.

Q26. Derived from syllabus

From which perspectives must security testing practices be evaluated, according to the syllabus?

a) Only from a cost perspective

b) Only from the perspective of the most recent release

c) Short-term and long-term; process and organization; people, tools, systems and techniques ✔

d) Developer productivity and defect density

Correct answer: c | LO: AS-2.7.1 (K4) | Syllabus §2.7

Why: (c) — §2.7 lists exactly these three evaluation perspectives.

Most Important Questions From This Chapter

Ranking rationale: three K3 questions are guaranteed (AS-2.4.2, 2.5.1, 2.6.3 — 6 points); one K4 (3 points) comes from 2.6.1/2.6.2/2.7.1; two K2 (2 points) from 2.2.1/2.3.1/2.4.1/2.4.3.

Rank	Topic / question focus	LO	Why it matters
1	Policy first; failure causes — Q5, Q21, Q22	AS-2.6.2	**3 points** if drawn; also explains Q9's logic across the paper.
2	Stakeholder benefits — Q6, Q23, Q24	AS-2.6.3	**Guaranteed 2 points.** Six rows to learn.
3	Scope vs integrity — Q4, Q17, Q18	AS-2.5.1	**Guaranteed 2 points.** Too small / too large.
4	Identifying objectives — Q3, Q14, Q15	AS-2.4.2	**Guaranteed 2 points.** Security vs functional filter.
5	KPIs and approaches — Q19, Q20, Q25, Q26	AS-2.6.1 / 2.7.1	Other candidates for the 3-point K4.
6	Purpose, context, alignment, IA — Q1, Q2, Q7–Q13, Q16	AS-2.2.1 / 2.3.1 / 2.4.1 / 2.4.3	Two K2 points; due diligence and IA ⊃ testing are the reliable ones.

Section 5 — Exam Tricks

5.1 Frequently tested topics (evidence-based)

LO	K	Qs	Pts	Sample #	Format used officially
AS-2.2.1	K2	pool	1	#5	"How does it help … to have done security testing?" → **due diligence**
AS-2.4.3	K2	pool	1	#6	"Which is a correct statement?" → **security testing is part of IA**
AS-2.4.2	**K3**	1	**2**	#7	Numbered list of 7 candidate objectives → pick the **security** four
AS-2.5.1	**K3**	1	**2**	#8	Scope expanded by edict → **too large, resources depleted**
AS-2.6.x / 2.7.1	**K4**	1	**3**	#9	Long failed-program scenario → **policy + testing policy first**
AS-2.6.3	**K3**	1	**2**	#10	Fraud / credit card → **business customers**
Chapter 2 total	—	**6**	**11**	**#5–#10**	**14% of the points at 5.1 points per teaching hour**

The arithmetic

Chapter 2's **three K3 questions are each worth two K2s**. Learning **three short lists** — six stakeholder benefits, the two scope consequences, the three sources of objectives — secures **6 points**, more than an entire K2-only chapter would give.

5.2 Common distractors observed

- **Using test records for forensics or recovery** (track the perpetrator, restore from the pre-test backup) instead of **due diligence**.
- **IA inside security testing**, or the two being the same — the hierarchy is **IA ⊃ testing**.
- **Functional items in a security-objective list** — retry counts without lockout, emailing a password, admin resets.
- **Worries that may be controllable** ("not well-focused", "not clearly defined") beside the syllabus consequence (**too large → resources depleted**).
- **Approach before policy** — presenting a test approach to executives who have no policy to anchor it.
- **The stakeholder who is involved but not the primary beneficiary** — executives and regulators for a fraud-protection objective.

5.3 Keyword recognition (map words → answers)

If the stem says…	Think…
"legal action", "court", "breach occurred"	**Due diligence**
"assurance to clients"	**Confidence and trust**
"information assurance"	**Broader than** security testing (like QA)
"scope expanded immediately"	**Too large → resources depleted**
"only the login page"	**Too small → no confidence**
"agreed in principle, no budget"	**Lack of executive leadership / resources → write the policy**
"fraud", "credit card"	**Business customers**
"legal obligations", "internal policy"	**Compliance officers**
"external laws", "regulations"	**Regulatory officers**
"private data", "personal information"	**Privacy officers**
"due diligence" as a stakeholder benefit	**Senior management**

If the stem says...	Think...
"business protection"	**Executive management**
"post-release vulnerabilities"	**Effectiveness KPI** — locate when and where

5.4 Typical traps

- **Senior vs executive management.** Executive → **business protection**; senior → **due diligence**. Learn the pair.
- **Compliance vs regulatory officers.** Compliance = **internal** corporate policies, legal obligations. Regulatory = **external** security laws.
- **Strategy vs approach.** Strategy = **organization** level overall direction. Approach = **project** level blend of techniques, tools, skills.
- **Degrees of failure.** One missed vulnerability does **not** by itself mean the approach failed — but a missed vulnerability **in an area the policy required testing** does indicate failure.
- **IA properties.** The IA definition includes **authentication and non-repudiation**, not only CIA.

5.5 How to eliminate wrong answers

5. **Strike anything that guarantees** safety, completeness or zero vulnerabilities.
6. **Strike options that skip a level of the hierarchy** — approach without policy, testing policy before security policy.
7. In objective lists, **strike items with no security consequence** stated in the stem.
8. In stakeholder questions, **find the stakeholder whose own asset or duty is at stake**.
9. In KPI questions, **strike options that call a high, stable metric a problem** because it is not 100%.

5.6 Scenario-solving shortcuts

Scenario shape	Shortcut
Long story of sporadic, undocumented, unfunded testing	**Policy and testing policy, aligned to the approach**
Management widens scope after a breach	**Resources may run out** before testing finishes
List of candidate objectives	Keep only those that verify **the security feature named**
New technology (mobile, cloud, mainframe) in the scenario	Add objectives for **technology attributes** — e.g. data in transit
Team lacks skills / environment	The approach **least likely to succeed** ignores that constraint
KPI table	Find the **low coverage + post-release escapes**; leave the high stable ones alone

5.7 Common candidate mistakes

- Answering stakeholder questions by **seniority** rather than by **whose benefit** the stem describes.
- Forgetting that §2.1's list of threats (XSS, buffer overflow, MITM, logic bombs...) is examinable vocabulary everywhere.
- Treating "security testing is often outsourced" as advice — it is an **observation** about the organizational context.
- Missing that the syllabus says security testing is **often one type of functional testing**.

5.8 Mnemonics that carry the whole chapter

Mnemonic	Expands to
F-T-V ("Feature, Tech, Vuln")	Sources of security test objectives
Small = Sure-not; Large = Lack	Scope too small → no confidence; too large → lack of resources

Mnemonic	Expands to
"EBe, SDue, CuFraud, CoLaw, ReReg, PriPriv"	Executive–business protection · Senior–due diligence · Customers–fraud · Compliance–legal obligations · Regulatory–regulations · Privacy–private data
P → TP → S → A → T	Security Policy → Testing Policy → Strategy → Approach → Tasks
AIACN	IA properties: Availability, Integrity, Authentication, Confidentiality, Non-repudiation
R-P-R KPIs + E	Coverage of **R**isks, **P**olicies, **R**equirements; **E**ffectiveness (when and where, pre/post release)

5.9 Chapter 2 mind map

Branch	Leaves
Why	Identify risks · evaluate defenses · due diligence · assurance · cannot guarantee safety
Context	Risk drives extent · specialist/outsourced · lifecycle activity · six realities
Objectives	Aligned to policy · per feature + technology + vulnerabilities · IA ⊃ testing · scope ↔ integrity
Approaches	Strategy vs approach · 13 factors · technology-specific · 12 failure causes · RCA
People	Business case · six stakeholder benefits
Improvement	Short/long term · process/organization · people/tools/systems/techniques · four KPIs

Section 6 — Revision Notes

6.1 One-page chapter summary

Why: security testing assesses vulnerability by trying to compromise the security policy. It cannot guarantee safety, but it identifies risks, evaluates defenses, demonstrates **due diligence** (a possible legal defense) and gives clients **assurance**. **Where:** its extent is driven by security-based business risk; it is a lifecycle activity — security cannot be patched or tested in; success depends on time, resources, scope, risk, skills and lifecycle.

What: the security testing policy follows and aligns to the approved security policy. Objectives exist **per security feature**, and also from **technology attributes** and **known vulnerabilities**. IA is the umbrella; testing sits inside it. Coverage grows with the **integrity need** of the assets — but too small a scope gives no confidence and too large a scope runs out of resources.

How: the strategy sets direction; project approaches implement it, shaped by thirteen situational factors and by technology. When approaches fail, root cause analysis finds the cause among twelve. A business case wins management; each stakeholder sees a different benefit. Practices improve by measuring coverage of risks, policies and requirements, and effectiveness pre- and post-release.

6.2 Key definitions to memorize

Term	Definition
Information assurance	Protect and defend information and systems: availability, integrity, authentication, confidentiality, non-repudiation; restoration via protection, detection, reaction
Security testing	Determine security features are implemented as designed and adequate for the environment
Security test strategy	The organization's overall direction for security testing
Security test approach	Project-level blend of techniques, tools and skills implementing the strategy

6.3 High-priority concepts (study first)

10. Stakeholder → benefit table (**AS-2.6.3**, 2 pts guaranteed).
11. Scope too small / too large (**AS-2.5.1**, 2 pts guaranteed).
12. Objective sources and the security-vs-functional filter (**AS-2.4.2**, 2 pts guaranteed).
13. Policy first; twelve failure causes; thirteen approach factors; four KPIs (**K4 pool**, 3 pts).
14. Due diligence; IA ⊃ testing; six realities; alignment (**K2 pool**, 2 pts).

6.4 Last-minute revision sheet

If you read nothing else

Breach + legal action → **due diligence**. IA ⊃ security testing.

Extent driven by **security-based business risk**. Can't patch or test security in.

Security policy (senior mgmt) → testing policy → strategy → approach. Misaligned = unauthorized tests or missed purposes.

Objectives: ≥1 per security feature + technology attributes + known vulnerabilities. Retry counts and email resets are functional.

More integrity need → more coverage. Too small = no confidence; too large = resources depleted.

Exec = business protection · Senior = due diligence · Customers = fraud · Compliance = legal obligations · Regulatory = regulations · Privacy = private data.

Failed approach → RCA; leadership, resources, alignment, skills, information. Fix = **policy first**.

KPIs: coverage of risks, policies, requirements; effectiveness pre/post release.

6.5 Memorization checklist

✓	I can…
☐	list the §2.1 threats and describe XSS, buffer overflow, MITM and logic bombs
☐	state what security testing can and cannot do, and its legal benefit
☐	name the six realities that affect a security test team
☐	explain the policy hierarchy and the two consequences of misalignment
☐	filter a list of objectives into security and functional
☐	quote the IA definition's five properties and place IA relative to testing
☐	state the scope rule and both consequences
☐	list ten of the thirteen approach factors and ten of the twelve failure causes
☐	map all six stakeholders to their benefits
☐	name the four KPIs and interpret a KPI table

6.6 Exam-day quick review

- Three K3 questions = **6 points** from three lists. Do them carefully but quickly.
- **Fraud → customers. Law → regulators. Internal policy → compliance. Privacy → privacy officers.**
- **Long sad scenario → policy first.**